

VetAI Türk hukuku ve KVKK inceleme paketi

Sürüm tarihi: 10 Ağustos 2026

İncelenen teknik ürün sürümü: **0a3e13d**

Belgenin amacı ve sınırı

Bu belge, VetAI MVP'sinin mevcut veri akışını hukuk/KVKK uzmanına anlaşılır biçimde gösteren bir inceleme ve karar çalışma kâğıdıdır. Hazır bir aydınlatma metni, açık rıza metni, kişisel veri işleme envanteri veya saklama ve imha politikası değildir. Hukuki sebep ve saklama süresi seçmez; uzman bu kararları veri sorumlusunun gerçek işleyişine göre vermelidir.

Teknik ekip ve yapay zekâ, "KVKK'ya uygundur" onayı veremez. Üretime geçmeden önce bu belgedeki açık alanlar yetkili uzman ve veri sorumlusu tarafından tamamlanmalı; gerekli aydınlatma, sözleşme ve politika metinleri ayrıca hazırlanmalıdır.

Teknik terimler için kısa sözlük

- Tenant / klinik sınırı:** Her kliniğin kayıtlarının diğer kliniklerden veritabanı seviyesinde ayrılması.
- Webhook:** WhatsApp/Meta'nın yeni mesaj veya teslimat olayı olduğunda sisteme gönderdiği imzalı teknik bildirim.
- Worker:** Webhook'u karşılayan ve doğrulayan Cloudflare üzerindeki sunucu kodu; kullanıcının telefonunda çalışmaz.
- Queue:** İşin daha sonra güvenli biçimde işlenmesi için tutulan sıra. DLQ ise birkaç denemede işlenemeyen işi kaybetmeden bekleten hata sırasıdır.
- Outbox:** Kullanıcıya gönderilmesi planlanan mesajın, gönderimden önce ve gönderim sonucu kaydedilirken tutulduğu veritabanı bölümü.

- RLS (satır düzeyi güvenlik): Personelin yalnız yetkili olduğu kliniğin satırlarını görebilmesini sağlayan veritabanı kuralı.
- Service role: Yalnız sunucu tarafında bulunan, son kullanıcıya veya tarayıcıya verilmeyen yüksek yetkili teknik kimlik.
- Hash: İçeriğin kendisini saklamadan aynı olayın tekrar gelip gelmediğini kontrol etmeye yarayan tek yönlü özet değer.
- API secret / token: Servislerin birbirini doğruladığı gizli anahtar; mesaj veya kullanıcı verisi değildir ve istemciye gösterilmez.

1. Önce belirlenmesi gereken taraflar

Karar	Uzmanın dolduracağı alan
Veri sorumlusu kimdir? Klinik, platform işletmecisi veya ortak sorumluluk ihtimali değerlendirilmelidir.	
Veri sorumlusu iletişim ve başvuru kanalı	
Veri işleyenler ve alt işleyenler	
Klinik çalışanlarının yetki ve sorumlulukları	
VERBİS yükümlülüğü / istisna durumu	
Yurt dışına aktarım yapan taraf ve uygun güvence yöntemi	

Bu roller yalnız sözleşmedeki unvana göre değil, işleme amaç ve yöntemlerine gerçekte kimin karar verdiğine göre uzman tarafından belirlenmelidir.

2. Sistemin sade veri akışı

1. Hayvan sahibi kliniğin WhatsApp numarasına yazar.
2. Meta, imzalı webhook içeriğini Cloudflare Worker'a iletir.
3. Worker imzayı doğrular; telefon, ad ve mesajı kliniğin Supabase

veritabanında tenant sınırlarıyla saklar.

4. Cloudflare Queue yalnız konuşma ve sağlayıcı mesaj kimliklerini taşır; ham mesaj metni Queue gövdesine kopyalanmaz.

5. Güncel mesaj metni, yapılandırılmış bilgi çıkarımı için OpenAI'a gönderilir.

İstekte telefon, ad veya ham veritabanı kimliği yerine tek yönlü bir güvenlik tanımlayıcısı kullanılır ve **store: false** ayarlanır. Bunun sağlayıcının tüm yasal/operasyonel saklamasını sıfırladığı varsayılmamalı; sözleşme ve hesap veri kontrolleri ayrıca incelenmelidir.

6. Kesin güvenlik ve akış kararını yapay zekâ değil, sabit kurallar verir.

7. Sabit WhatsApp yanıtı outbox'a yazılır ve Meta Cloud API üzerinden gönderilir.

8. Yetkili klinik personeli Supabase Auth ile yalnız üyesi olduğu kliniğin personel iş kayıtlarını görüntüler.

3. Doğrulanmış teknik veri envanteri

Veri grubu	Tutulan örnek alanlar	Amaç / mevcut kullanım	Kayıt yeri ve erişim
Klinik ve personel	Klinik adı, personel kullanıcı kimliği, rol	Tenant ve yetki yönetimi	Supabase; personel yalnız üyesi olduğu klinik kapsamında
WhatsApp hesabı	Meta phone_number_id , görünen hesap adı	Gelen/giden mesajı doğru klinik hesabına bağlama	Supabase; sırlar burada tutulmaz
Hayvan sahibi	Ad-soyad, E.164 telefon numarası	İletişim kuran kişiyi klinik içinde tanıma	Supabase; klinik bazında ayrılmış
Evcil hayvan	Ad, tür, sahip ve klinik bağlantısı	Doğru hayvanı konuşma/randevuyla eşleme	Supabase; sahip ve klinik ilişkisi veritabanı kısıtlarıyla korunur
Konuşma ve intake	Seçili hayvan, akış aşaması, yapılandırılmış şikâyet, belirtiler, güvenlik cevapları, insan/randevu talebi	Dijital resepsiyon, güvenlik yönlendirmesi ve randevu akışı	Supabase; konuşma sahibine ve kliniğe bağlı
Mesaj	Gelen/giden yönü, ham metin, WhatsApp mesaj kimliği, zaman	Konuşma geçmişi ve tekrar işleme koruması	Supabase; konuşmayla birlikte silme zincirine bağlı
Webhook olayı	Sağlayıcı olay kimliği, payload hash'i, işlem durumu, sınırlı hata özeti	Tekrar işleme/idempotency ve operasyon	Supabase; ham webhook veya token tutulmaz
Giden yanıt	Alıcı telefon numarası, sabit yanıt metni, kategori, gönderim/teslim durumu, deneme sayısı, sağlayıcı mesaj kimliği	Güvenilir WhatsApp gönderimi ve durum takibi	Supabase backend; personel tablosundan doğrudan görünmez

Veri grubu	Tutulan örnek alanlar	Amaç / mevcut kullanım	Kayıt yeri ve erişim
Personel iş kaydı	Konuşma/outbox kimliği, neden, normal/acil öncelik, açık/çözüldü durumu	İnsan müdahalesi gereken işi görünür kılma	Supabase; telefon ve mesaj içeriği içermez
Randevu	Başlangıç/bitiş zamanı, durum, konuşma/sahip/hayvan bağlantısı, geçici token ve süre	Geçici ayırma ve açık EVET sonrası onay	Supabase; klinik bazında ayrılmış
Kimlik doğrulama	Supabase Auth kullanıcı hesabı ve oturum verileri	Personel girişi	Supabase Auth; uygulama tabloları yalnız kullanıcı UUID'sini referanslar
Queue/DLQ	Konuşma ve sağlayıcı mesaj kimliği	Dayanıklı arka plan işleme ve hata kurtarma	Cloudflare Queues; ham mesaj metni yok
Teknik secret'lar	API anahtarları ve webhook secret'ları	Servisler arası kimlik doğrulama	Yalnız Cloudflare şifreli Worker binding'leri; veritabanı/istemci kodunda yok

Not: Evcil hayvana ilişkin sağlık anlatımının gerçek kişiyle bağlantılı olduğu durumlarda hukuki niteliği ve uygulanacak koruma seviyesi uzman tarafından belirlenmelidir; bu belge kendiliğinden “özel nitelikli kişisel veri” veya “kişisel veri değildir” sonucu çıkarmaz.

4. İşleme faaliyeti karar tablosu

Her satırda amacı, hukuki sebebi ve aktarımı ayrı ayrı belirleyin. “Hizmet için gerekli” gibi genel bir ifade tek başına hukuki sebep yerine yazılmamalıdır.

Faaliyet	Veri konusu kişi / veri	Hukuki sebep	Alıcı veya alıcı grubu	Yurt dışı aktarım yöntemi	Uzman kararı/notu
WhatsApp mesajını alma ve yanıtlama	Hayvan sahibi; telefon, ad, mesaj		Meta, Cloudflare, Supabase		
Şikâyet ve güvenlik bilgisini yapılandırma	Hayvan sahibiyle bağlantılı konuşma ve evcil hayvan bilgisi		OpenAI, Supabase		
Klinik personeline iş görünürlüğü	Konuşma ve yönlendirme nedeni		Yetkili klinik personeli, Supabase		
Randevu oluşturma	Sahip/hayvan bağlantısı ve zaman		Klinik personeli, Supabase, Meta		
Mesaj teslimat takibi	Telefon, sağlayıcı kimliği ve sabit yanıt		Meta, Cloudflare, Supabase		
Güvenlik, hata önleme ve olay kaydı	Hash, teknik kimlikler, sınırlı hata özeti		Cloudflare, Supabase		
Personel kimlik doğrulama	Personel hesabı ve oturum		Supabase Auth		

5. Aydınlatma metni için karar listesi

Aydınlatma, açık rızadan ayrı değerlendirilmelidir. Uzman en az aşağıdakileri belirlemeli ve WhatsApp'ta verinin elde edildiği anda veya uygun ilk temas noktasında nasıl gösterileceğini kararlaştırmalıdır:

- ☐ Veri sorumlusunun ve varsa temsilcisinin kimliği.
- ☐ Her işleme faaliyetinin belirli, açık ve meşru amacı.
- ☐ Verilerin kimlere, hangi amaçlarla aktarılabileceği.
- ☐ Toplama yöntemi ve her faaliyet için hukuki sebep.
- ☐ İlgili kişinin hakları ve başvuru kanalı.
- ☐ Yurt dışı aktarımın kapsamı ve uygulanan güvence.
- ☐ Aydınlatmanın gösterildiğinin nasıl ispatlanacağı.
- ☐ Amaç değişirse yeni aydınlatmanın nasıl yapılacağı.

Kararlaştırılan gösterim noktası ve metin sürümü: _____

6. Saklama ve imha karar tablosu

Projede genel amaçlı otomatik saklama/imha işi yoktur. Sahip, klinik ve bağlı kayıtlar için veritabanı silme zincirleri vardır; bu, hukuken gerekli saklama süresinin belirlendiği veya yedeklerin/sağlayıcı kayıtlarının silindiği anlamına gelmez. Süreleri aşağıda uzman ve veri sorumlusu doldurmalıdır.

Kayıt grubu	Mevcut teknik durum	Azami saklama süresi	Süre başlangıcı	İmha yöntemi / periyot	Hukuki gerekçe ve sorumlu
Sahip, hayvan, konuşma, ham mesaj ve intake	Sahip/klinik silme zincirine bağlı; otomatik süre yok				
Webhook olayları ve hash	Otomatik süre yok; bağlı outbox dikkate alınmalı				
Bekleyen/işlenen outbox	Silinmesi gönderilmemiş yanıtı düşülebilir; sahip/hesap/olay silme zinciri var				
Kabul/teslim edilmiş outbox	Telefon ve sabit yanıtı tutar; otomatik süre yok				
Personel iş kayıtları	Kaynak konuşma/outbox ile silinir; otomatik süre yok				

Kayıt grubu	Mevcut teknik durum	Azami saklama süresi	Süre başlangıcı	İmha yöntemi / periyot	Hukuki gerekçe ve sorumlu
Randevu kayıtları	Klinik/konuşma/sahip/hayvan bağlantılarıyla silme zinciri var; otomatik süre yok				
Supabase Auth hesabı ve oturumları	Ayrı kimlik doğrulama yaşam döngüsü				
Cloudflare Queue/DLQ/terminal DLQ	Sağlayıcı saklama davranışı ve terminal kuyruk kurtarma penceresi sözleşmeden doğrulanmalı				
Uygulama ve güvenlik logları	Ham mesaj/secret loglanmıyor; altyapı log ayarları ayrıca doğrulanmalı				
Yedekler	Production yedekleme politikası henüz belirlenmedi				
Meta, OpenAI, Cloudflare ve Supabase tarafındaki sağlayıcı kayıtları	Sözleşme, bölge ve hesap ayarlarına bağlı				

Saklama şartı ortadan kalktığında silme, yok etme veya anonimleştirme yöntemi; periyodik imha süresi; yedeklerde uygulanma yöntemi ve sorumlu unvan ayrıca yazılmalıdır.

7. Yurt dışı aktarım ve sağlayıcı sözleşmeleri

Cloudflare, Meta, OpenAI ve Supabase için aşağıdaki bilgiler üretim hesabının gerçek sözleşme ve bölge ayarlarından doğrulanmalıdır:

Sağlayıcı	Rolü	İşlenen/aktarılan veri	Veri konumu ve alt işleyenler	Uygun güvence / sözleşme	Kurum bildirimi gerekiyorsa tarih
Cloudflare	Worker ve Queue altyapısı				
Meta / WhatsApp	Mesajlaşma kanalı				
OpenAI	Güncel mesajdan yapılandırılmış çıkarım				
Supabase / barındırma sağlayıcısı	Veritabanı, Auth ve API				

Standart sözleşme kullanılacaksa güncel Kurum metni, doğru taraf tipi, imza/bildirim süresi ve değişiklik yasağı hukuk uzmanı tarafından kontrol edilmelidir. Bu depo herhangi bir aktarım mekanizmasının tamamlandığını iddia etmez.

8. İlgili kişi başvurusu, düzeltme, dışa aktarma ve silme

Süreç kararı	Doldurulacak alan
Başvuru kanalı/adresi	
Başvuranın kimliğini doğrulama yöntemi	
Talebin alınması ve yasal sürenin takibi için sorumlu	
Telefon numarasıyla klinik içi kayıt arama yöntemi	
İhracata dâhil edilecek tablolar/sağlayıcı kayıtları	
Yanlış veriyi düzeltme ve aktarılan taraflara bildirme yöntemi	
Silme talebinde aktif randevu, bekleyen mesaj ve hukuki saklama çatışmasının çözümü	
Supabase Auth, yedek ve sağlayıcı kopyalarında silme yöntemi	
Talep sonucu ve yapılan işlemlerin ispat kaydı	

Mevcut veritabanı tenant bazlı silme zincirleri owner/clinic bağlantılı birçok kaydı birlikte kaldırır. Ancak üretim için yetkili bir başvuru/doğrulama ve silme aracı henüz yoktur; silme işlemi genel SQL erişimine veya yapay zekâya bırakılmamalıdır.

9. Mevcut teknik ve idari güvenlik gerçekleri

- Webhook imzası ham gövde üzerinden doğrulanır; boyut ve içerik türü sınırı vardır.
- Tenant ilişkileri **clinic_id**, bileşik yabancı anahtarlar ve RLS ile veritabanında korunur.
- Servis rolü secret'ı tarayıcıya verilmez; personel sayfası anonim anahtar ve Supabase Auth oturumuyla çalışır.
- Ham mesajlar, tokenlar ve servis secret'ları uygulama loglarına yazılmaz.
- Yapay zekâ serbest SQL çalıştıramaz ve kullanıcı/klinik veritabanı kimliği seçemez.

- Queue gövdesi ham mesaj taşımaz.
- Personel iş kaydı telefon veya mesaj içeriği taşımaz; iş kaydı oluşması personele bildirim gönderildiği anlamına gelmez.
- Acil yönlendirme deterministik kurallarla yapılır; veteriner onayı ayrıca gereklidir.

Uzmanın veya güvenlik sorumlusunun istediği ek tedbirler: _____

10. Üretim öncesi hukuk/KVKK kontrol listesi

- [] Veri sorumlusu/veri işleyen rolleri yazılı olarak belirlendi.
- [] İşleme envanteri ve faaliyet bazlı hukuki sebepler tamamlandı.
- [] Aydınlatma metni ve gösterim zamanı onaylandı.
- [] Gerekli ise açık rıza, aydınlatmadan ayrı tasarlandı.
- [] Saklama ve imha süreleri, periyodik imha ve sorumlular belirlendi.
- [] İlgili kişi başvuru, düzeltme, dış aktarma ve silme süreci belirlendi.
- [] Yurt dışı aktarım mekanizması ve gerekli bildirimler tamamlandı.
- [] Cloudflare, Meta, OpenAI, Supabase ve alt işleyen sözleşmeleri incelendi.
- [] VERBİS yükümlülüğü ve kayıtların envanterle uyumu değerlendirildi.
- [] Veteriner hekim metin onayı ayrıca kaydedildi.
- [] Production veri bölgesi, yedekleme, log ve erişim ayarları doğrulandı.

11. Resmî başvuru kaynakları

- [Aydınlatma Yükümlülüğünün Yerine Getirilmesinde Uyulacak Usul ve Esaslar Hakkında Tebliğ](#)
- [Kişisel Veri İşleme Envanteri Hazırlama Rehberi](#)
- [Kişisel Verilerin Silinmesi, Yok Edilmesi veya Anonim Hale Getirilmesi Hakkında Yönetmelik](#)

- [Başvuru Hakkı](#)
- [Yurt Dışına Aktarım](#)
- [Veri sorumlusu ve veri işleyenin belirlenmesine ilişkin Kurul kararı özeti](#)

Bu bağlantılar başlangıç noktasıdır. Uzman inceleme tarihinde mevzuatın, Kurul kararlarının ve sağlayıcı sözleşmelerinin güncel hâlini ayrıca kontrol etmelidir.

12. Hukuk/KVKK onay kaydı

Veri sorumlusu / klinik: _____
İnceleyen uzman: _____
Unvan / yetki bilgisi: _____
İnceleme tarihi: _____
İncelenen teknik sürüm: **0a3e13d**
Karar: [] Üretim öncesi hukuk kapıları tamam [] Düzeltme gerekli [] Onaylanmadı
Eksik belgeler / koşullar: _____
İmza / kurum içi onay kaydı: _____

İmzalı, iletişim bilgili veya hukuki görüş içeren tamamlanmış kopyayı bu herkese açık olabilecek kod deposuna koymayın. Veri sorumlusunun yetkili ve erişimi sınırlı kayıt ortamında saklayın.